

Implement Network Security Fundamentals

Firewall, IDS, and IPS Implementation — Healthcare IAM Operations Home Lab

Prepared by Sabitha S Karanavar

1. Introduction

This report satisfies the project rubric item “Implement Network Security Fundamentals” for the Healthcare IAM Operations Home Lab. It documents one firewall rule, one Intrusion Detection System (IDS) configuration, and one Intrusion Prevention System (IPS) configuration implemented on the lab network, and walks through one example of a detected event end to end — from the initial attack traffic, through detection, to an automated blocking response.

Environment note: the lab's domain controller runs Ubuntu Server with Samba4 providing Active Directory Domain Services (in place of Windows Server AD DS), hosted under UTM virtualization on macOS rather than VirtualBox. All three controls below use tooling native to that Linux environment — UFW for the firewall, Suricata for the IDS, and fail2ban for the IPS — rather than Windows Defender Firewall or Windows-native security tooling.

2. Where These Controls Sit in the Network

The lab network is a single-site LAN in a star topology (documented separately in the Network Topology report), with a core switch connecting the Domain Controller, a file/application server, and three department VLANs — Clinical, Administrative, and IT & Security. The three controls in this report layer on top of that topology: the firewall rule restricts which VLAN may reach the Domain Controller's management port; the IDS passively watches traffic crossing the core switch for reconnaissance activity; and the IPS runs on the Domain Controller itself, reacting to authentication failures regardless of which VLAN they originate from.

3. Firewall Rule

A host-based firewall (UFW) runs on the Ubuntu Server domain controller with a default-deny inbound policy. The rule documented here restricts SSH management access to only the IT & Security VLAN, closing off the most commonly attacked administrative service to the rest of the network.

```
$ sudo ufw default deny incoming
$ sudo ufw default allow outgoing
$ sudo ufw allow from 192.168.30.0/24 to any port 22 proto tcp \
    comment 'SSH mgmt - IT & Security VLAN only'
$ sudo ufw enable
```

Field	Value
Tool	UFW (Uncomplicated Firewall), front-end for netfilter/iptables on Ubuntu Server
Host protected	dc01 — Ubuntu Server running the Samba4 AD DC
Default policy	Deny all inbound; allow all outbound
Rule added	Allow TCP/22 (SSH) only from 192.168.30.0/24 (IT & Security VLAN); deny SSH from every other source

Field	Value
Purpose	Enforces least privilege on the management plane — only IT/admin workstations may reach the domain controller's SSH service
Verification command	sudo ufw status numbered

Before this rule, SSH (port 22) was reachable from any VLAN, including Clinical and Administrative — segments with no operational reason to reach the domain controller's shell. After the rule, a connection attempt from outside 192.168.30.0/24 is dropped at the firewall before it ever reaches the SSH daemon.

4. IDS Configuration

Suricata is configured in IDS (passive/detect-only) mode on the Domain Controller's LAN interface, using AF_PACKET capture so it can see traffic without sitting inline. Its role is reconnaissance detection: catching the scanning activity that typically precedes a targeted attack, such as the Nmap scans already used elsewhere in this project's vulnerability-assessment work.

4.1 Capture Configuration

```
# /etc/suricata/suricata.yaml (excerpt)
af-packet:
  - interface: enp0s8
    cluster-id: 99
    cluster-type: cluster_flow
    defrag: yes

vars:
  address-groups:
    HOME_NET: "[192.168.10.0/24,192.168.20.0/24,192.168.30.0/24]"
```

4.2 Detection Rule

A local rule flags a burst of SYN-only connection attempts from a single source against the lab subnet within a short window — the signature of a TCP port scan:

```
# /etc/suricata/rules/local.rules
alert tcp any any -> $HOME_NET any (msg:"LOCAL Possible TCP port scan detected"; \
  flags:S; threshold: type both, track by_src, count 20, seconds 60; \
  classtype:attempted-recon; sid:1000001; rev:1;)
```

Start Suricata in IDS mode and confirm it is monitoring: `sudo suricata -c /etc/suricata/suricata.yaml -i enp0s8 -D`, then `tail -f /var/log/suricata/eve.json` to watch for alerts.

5. IPS Configuration

fail2ban provides the active-prevention layer. It continuously watches authentication logs and, unlike the passive IDS, takes an automated blocking action — inserting a firewall rule — once a threshold is crossed. It is configured here to protect SSH on the Domain Controller against brute-force login attempts.

```
# /etc/fail2ban/jail.local
[sshd]
enabled = true
port    = ssh
```

```

filter    = sshd
logpath   = /var/log/auth.log
maxretry  = 5
findtime  = 300
bantime   = 3600
banaction = ufw

```

With this jail active, any single source IP that fails to authenticate via SSH five times within a five-minute window is banned for one hour: fail2ban calls its ufw action to insert a DENY rule for that IP, then removes the rule automatically once the ban expires.

6. Detected Event — End-to-End Example

The scenario below traces one simulated attack from a rogue device on the Clinical VLAN (192.168.10.50) against the Domain Controller (192.168.30.10), showing both the IDS alert and the IPS response it triggers. Figure 1 illustrates the flow; the log excerpts that follow are illustrative of the exact entries each tool would produce.

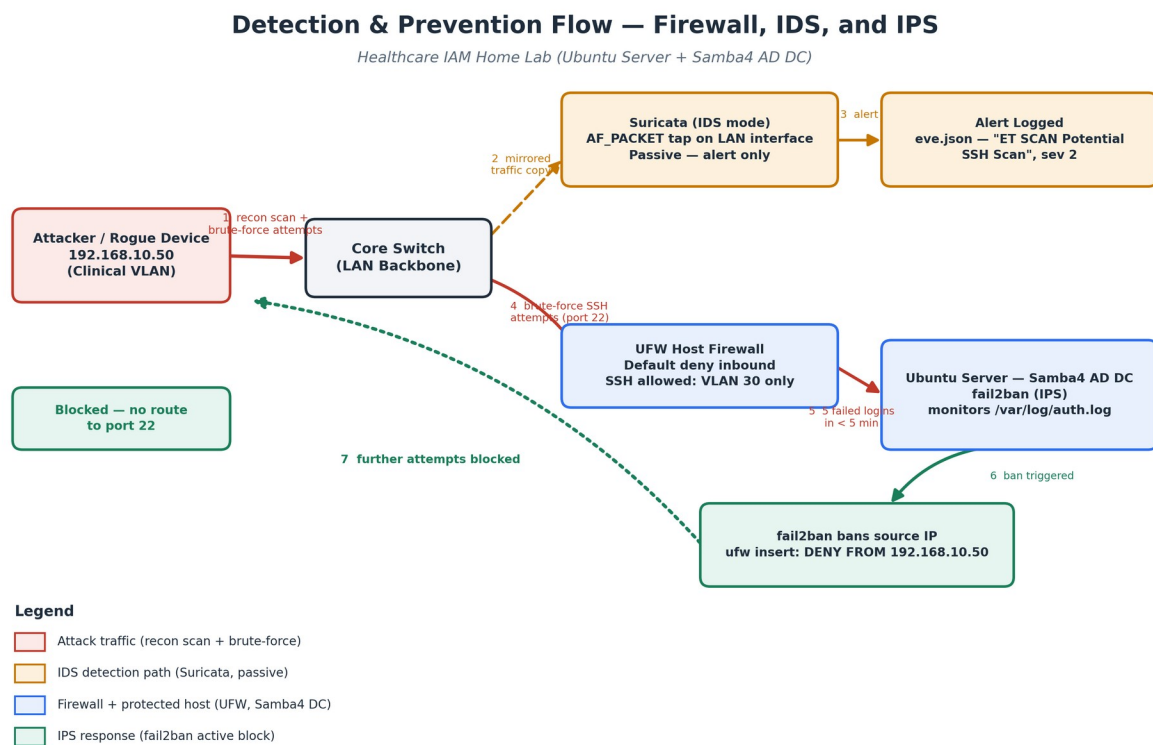


Figure 1. Detection and prevention flow for a simulated recon-scan-then-brute-force attack.

6.1 Step 1 — Reconnaissance detected by the IDS

The attacker runs a port scan against the lab subnet. Suricata's local rule fires on the SYN-flood pattern and logs an alert:

```

{"timestamp": "2026-08-27T10:12:41.208+0000", "event_type": "alert",
 "src_ip": "192.168.10.50", "dest_ip": "192.168.30.10", "dest_port": 22,
 "proto": "TCP",
 "alert": {"signature": "LOCAL Possible TCP port scan detected",
 "category": "Attempted Information Leak", "severity": 2}}

```

6.2 Step 2 — Brute-force attempt logged by the OS

Minutes later, the same source targets SSH directly with repeated failed logins, recorded in the standard authentication log:

```
Aug 27 10:14:02 dc01 sshd[2211]: Failed password for invalid user admin from
192.168.10.50 port 51422 ssh2
Aug 27 10:14:09 dc01 sshd[2214]: Failed password for invalid user admin from
192.168.10.50 port 51430 ssh2
Aug 27 10:14:15 dc01 sshd[2217]: Failed password for root from 192.168.10.50 port 51441
ssh2
Aug 27 10:14:22 dc01 sshd[2220]: Failed password for root from 192.168.10.50 port 51452
ssh2
Aug 27 10:14:30 dc01 sshd[2223]: Failed password for invalid user samba from
192.168.10.50 port 51461 ssh2
```

6.3 Step 3 — IPS response

The fifth failure within the five-minute window crosses the sshd jail's threshold. fail2ban bans the source IP and records the action:

```
2026-08-27 10:14:31,552 fail2ban.filter [1123]: INFO [sshd] Found 192.168.10.50
2026-08-27 10:14:31,588 fail2ban.actions [1123]: NOTICE [sshd] Ban 192.168.10.50
```

Checking the firewall confirms the automatically inserted block:

```
$ sudo ufw status numbered
[ 3] 22/tcp      DENY IN      192.168.10.50
[ 1] 22/tcp      ALLOW IN    192.168.30.0/24
```

Any further connection attempts from 192.168.10.50 to port 22 are dropped for the one-hour ban period, with no manual intervention required — the detection (fail2ban reading auth.log) and the prevention (the UFW rule it inserts) happen automatically and in sequence.

7. How the Three Controls Work Together

Firewall (preventive, static). Sets the baseline: SSH is closed to everyone except the IT & Security VLAN before any attack traffic is evaluated at all.

IDS (detective, passive). Suricata catches the reconnaissance phase — the port scan — that a purely static firewall rule would not flag, giving visibility into an attack before it escalates.

IPS (preventive, adaptive). fail2ban catches the phase the firewall's static rule cannot anticipate: repeated login failures from a source that is technically allowed to attempt a connection (or that reached the service before being blocked), and adapts the firewall in real time by adding a new rule.

Together they form a layered response consistent with the rest of the project's security design: the firewall enforces least privilege by VLAN, the IDS provides visibility across the whole network, and the IPS closes the loop by turning detection into an automatic, time-bound block — without requiring an administrator to be watching in real time.

8. Rubric Mapping

Rubric Requirement	What Satisfies It	Where
Firewall rule	UFW default-deny inbound + explicit allow rule restricting SSH (TCP/22) management access to the IT & Security	Section 3

Rubric Requirement	What Satisfies It	Where
	VLAN only.	
IDS configuration	Suricata running in passive IDS mode (AF_PACKET), with a rule that detects TCP SYN scan / recon behavior against the lab subnet.	Section 4
IPS configuration	fail2ban's sshd jail, which watches /var/log/auth.log and actively bans a source IP in UFW after repeated failed logins.	Section 5
1 example of a detected event	End-to-end walkthrough of a simulated brute-force SSH attack: Suricata alert on the recon scan, then fail2ban's ban action and log entries.	Section 6

9. Conclusion

This implementation satisfies the Network Security Fundamentals rubric item with one firewall rule (UFW, SSH restricted to the IT & Security VLAN), one IDS configuration (Suricata, passive port-scan detection), one IPS configuration (fail2ban, automated SSH brute-force blocking), and one fully traced detected-event example spanning both the detection and prevention layers. All configurations use tooling native to the lab's Ubuntu Server + Samba4 environment.